Job 07 — Remédiation et recommandations

Projet : Découverte et Exploitation de Vulnérabilités
Étudiant : Samet ARI — La Plateforme_
Cible : Metasploitable 2 (`192.168.47.133`)

1. Objectif

Après la détection (Job 04) et l'exploitation (Jobs 05-06), cette dernière phase propose les **corrections** pour chaque vulnérabilité exploitée, puis des mesures de sécurité générales. L'objectif n'est plus d'attaquer, mais de **fermer les portes** ouvertes et d'éviter que la compromission se reproduise.

> **Rappel du contexte :** deux vecteurs d'accès root indépendants ont été démontrés sur la même machine — la porte dérobée UnrealIRCd (type *backdoor / RCE*) et le service VNC à mot de passe faible (type *authentification faible*). La remédiation doit traiter les deux, ainsi que les autres critiques détectées.

2. Remédiation par vulnérabilité

2.1 UnrealIRCd — porte dérobée (CVE-2010-2075)

Problème	Version compromise d'UnrealIRCd contenant une porte dérobée (exécution de commandes à distance). Service exécuté en **root**.
Correction immédiate	Désinstaller la version compromise. Réinstaller depuis la **source officielle** en vérifiant la **signature (MD5/SHA)** du paquet.
Correction de fond	Faire tourner le service sous un **compte non privilégié** (principe de moindre privilège), et non en root.
Vérification	Re-scanner avec Nessus : le plugin *UnrealIRCd Backdoor Detection* ne doit plus remonter.

2.2 VNC — mot de passe faible

Problème	Service VNC (port 5900) protégé par le mot de passe `password`. Accès au bureau graphique **root** sans effort.
Correction immédiate	Définir un **mot de passe fort** (long, complexe, unique) ou **désactiver VNC** s'il n'est pas nécessaire.
Correction de fond	Ne jamais exposer le port 5900 sur un réseau non fiable. Préférer un accès distant chiffré et authentifié (ex. SSH avec tunnel), ou restreindre l'accès par pare-feu.
Vérification	Tester que `password` (et les mots de passe faibles courants) ne fonctionne plus.

2.3 Debian OpenSSH/OpenSSL — clés faibles (CVE-2008-0166)

Problème	Générateur de nombres aléatoires défectueux : clés SSH/SSL prévisibles, donc devinables par un attaquant.
Correction	**Régénérer toutes les clés** avec une version corrigée d'OpenSSL. Révoquer les anciennes clés compromises.
Vérification	Confirmer que les nouvelles clés ne figurent pas dans les listes de clés faibles connues.

2.4 Autres critiques (contexte Metasploitable 2)

Vulnérabilité	Correction
vsftpd 2.3.4 backdoor	Réinstaller vsftpd depuis une source fiable ; mettre à jour.
Samba `usermap_script`	Mettre à jour Samba ; désactiver l'option `username map script`.
DistCC	Désactiver, ou restreindre aux hôtes de confiance.
Telnet (cleartext)	Désactiver Telnet ; utiliser **SSH** à la place.
Bind shell (port 1524)	Identifier et supprimer la porte dérobée ; reconstruire l'hôte.
Apache / MySQL obsolètes	Mettre à jour vers des versions supportées ; mots de passe forts sur les comptes.

3. Mesures de sécurité transversales

Au-delà des corrections ponctuelles, quatre principes couvrent la plupart des failles trouvées :

Principe	Application concrète sur cette cible
Moindre privilège	Aucun service réseau ne doit tourner en root sans nécessité (le cas UnrealIRCd).
Mots de passe forts	Supprimer tous les mots de passe par défaut / faibles (VNC, MySQL, comptes `/etc/shadow`). Migrer les hachages MD5 (`$1$`) vers SHA-512.
Réduction de la surface d'attaque	Désactiver les services inutiles (IRC, Telnet, DistCC, VNC…). Moins de services ouverts = moins de portes.
Mises à jour régulières	La majorité des failles viennent de logiciels obsolètes. Appliquer les correctifs de sécurité en continu.

4. Priorisation des corrections

Toutes les failles ne se corrigent pas en même temps. Ordre recommandé, du plus urgent au moins urgent :

Priorité	Action	Justification
1 — Critique	Supprimer les portes dérobées (UnrealIRCd, vsftpd, bind shell)	Accès root direct, aucune barrière.
2 — Critique	Corriger les authentifications faibles (VNC, MySQL, comptes)	Accès trivial, exploité sans outil.
3 — Élevée	Désactiver les services en clair et inutiles (Telnet, DistCC)	Réduit la surface d'attaque.
4 — Continue	Mises à jour système + scans Nessus réguliers	Empêche la réapparition de failles.

5. L'importance des mises à jour et des audits

Ce TP illustre un point essentiel : **un seul service non maintenu a suffi à compromettre toute la machine**. UnrealIRCd datait de 2010 ; VNC utilisait un mot de passe trivial. Aucune de ces failles n'est récente ou sophistiquée — elles existent parce que le système n'a jamais été ni mis à jour, ni audité.

La **gestion des vulnérabilités** n'est donc pas une action ponctuelle mais un **processus continu** :

1. **Scanner régulièrement** (Nessus) pour détecter les nouvelles failles.
2. **Suivre les CVE** des logiciels utilisés.
3. **Appliquer les correctifs** de manière systématique.
4. **Re-tester** après chaque correction pour vérifier qu'elle est efficace.

C'est ce cycle — *détecter → corriger → vérifier* — qui transforme un système vulnérable en système défendable.

6. Synthèse du projet complet

Job	Phase	Résultat
01	Documentation Nessus	Outil et méthodologie documentés
04	Scan et analyse	9 critiques, classées par type
05-06	Exploitation + post-exploitation	**Accès root par deux vecteurs** (UnrealIRCd + VNC)
07	**Remédiation**	**Corrections par faille + principes + priorisation**

Chaîne de sécurité complète démontrée : détecter → analyser → exploiter → **corriger → vérifier**.